

AI Risk Intake and Impact Assessment

Proposed AI use / system name:

Request prepared by:

Business owner:

Date:

Version: 1.0

Type: ☐ Initial (pre-deployment) ☐ Annual review ☐ Material change ☐ Incident-triggered

Tier (from AI Risk Tiering Decision Tree): ☐ Tier 1 ☐ Tier 2 ☐ Tier 3

How to use. Use this form before approving a new AI tool, workflow, or material change to an existing system. For low-risk uses, complete Sections 1-4. For medium-risk uses, complete Sections 1-8. For higher-impact or regulated use cases, use the full form as the starter impact assessment record and route it for qualified review.

1. System snapshot

1.1 What is this system and what does it do (one paragraph, plain language)?

1.2 Who makes the system (vendor / in-house)? Model / version:

1.3 Who uses it? (teams, count, role)

1.4 Who does it affect? (customers, employees, candidates, patients, the public)

1.5 How does it fit into our work? (upstream input -> model -> downstream action)

2. Purpose, benefit, and necessity

2.1 Why do we want this system? What problem does it solve?

2.2 What specific benefit do we expect for the business?

2.3 What specific benefit do we expect for users / customers / affected people?

2.4 What alternatives did we consider? Why this one?

2.5 What would happen if we did nothing?

3. Decision and stakes

3.1 Does the system make or materially inform a decision about a person?

- ☐ No
- ☐ Yes - describe:

3.2 If yes, could a wrong decision affect (check all that apply):

- ☐ Employment, income, or career progression
- ☐ Access to credit or financial services
- ☐ Access to housing
- ☐ Access to insurance or healthcare
- ☐ Access to education
- ☐ Legal rights or legal services
- ☐ Government services or benefits
- ☐ Physical safety
- ☐ Personal dignity (privacy, reputation, identity)
- ☐ None of the above - explain:

3.3 Is the system subject to one or more of these laws for this use? (Check all)

- ☐ Colorado SB 26-189 / covered ADMT
- ☐ California TFAIA / other California AI law
- ☐ Texas TRAIGA
- ☐ Illinois AIVIA / BIPA
- ☐ NYC Local Law 144
- ☐ Utah AI Policy Act
- ☐ EU AI Act (high-risk Annex I / Annex III)
- ☐ GDPR / CCPA (automated decision-making provisions)
- ☐ HIPAA
- ☐ Fair-lending / fair-housing / ECOA / FCRA
- ☐ Sector rule:
- ☐ Other:

3.4 Overall stakes (pick one):

- ☐ Low - mistakes cost time or money to fix, not much more
- ☐ Medium - mistakes inconvenience people or cause reputational harm
- ☐ High - mistakes affect livelihoods, rights, safety, or access to essential services

4. Data

4.1 What data does the system take as input?

4.2 Does it include personal data?

- ☐ No
- ☐ Yes - what categories? (contact info, identifiers, behavioral, financial, health, biometric, children's, location, special categories)

4.3 Where does the data come from? (user submission, company records, third-party data, scraped, purchased)

4.4 Do we have a lawful basis to use it for this purpose? (consent, contract, legitimate interest, legal obligation - GDPR/CCPA terms)

4.5 How long is input data retained? Where is it stored?

4.6 For vendor systems: summary of training data (from developer documentation)

4.7 Is customer input used to train the vendor's models?

- ☐ No
- ☐ Yes
- ☐ Opt-out applies (confirmed opted out)

5. Outputs and actions

5.1 What does the system produce?

5.2 What happens after the output is produced? (human reviews, auto-action, queued for approval)

5.3 How do we confirm the output is correct before acting?

6. Risks

6.1 Accuracy and quality

- What does the system get wrong?
- How often?
- Who catches it?
- What's the downstream cost of an undetected error?

6.2 Bias and discrimination

- Could outputs vary by race, gender, age, disability, national origin, religion, sexual orientation, or other protected characteristics?
- What testing has been done?
- What proxies for protected classes might be in our inputs?

6.3 Privacy

- What personal data is at risk?
- What is the worst-case leak?
- Are any categories of data inappropriate for this tool?

6.4 Security

- Attack surface (prompt injection, data poisoning, model theft, credential abuse)
- Controls in place

6.5 Manipulation, deception, safety

- Could outputs deceive or manipulate people?
- Could outputs contain harmful content?
- Could outputs be used to cause physical or psychological harm?

6.6 IP and legal

- Could outputs infringe copyright, trademark, or other rights?
- Could outputs violate contractual restrictions?
- Are there confidentiality risks in how we use the tool?

6.7 Operational / dependency

- What happens if the vendor goes down, changes terms, or is acquired?
- Do we have a fallback?

6.8 Reputational

- If this made the news, how would it read?
- What would a skeptical journalist write?

7. Mitigations

For each risk identified above, describe the control, the owner, and how you'll know it's working.

Risk area	Mitigation	Owner	How measured
Accuracy			
Bias			
Privacy			
Security			
Manipulation			
IP / legal			
Operational			
Reputational			

7.1 What is the human-in-the-loop design? Where is the human? What authority do they have?

7.2 What is the override / kill switch procedure?

7.3 What training have users received?

8. Transparency and user-facing controls

8.1 Will users know they're interacting with AI? Where is the disclosure and what does it say?

8.2 If this affects decisions about people, how are those people notified?

8.3 Do users have any of the following? (check all that apply)

- ☐ Right to see what data was used
- ☐ Right to correct their data
- ☐ Right to opt out of AI assistance
- ☐ Right to appeal a decision to a human
- ☐ Right to an explanation of the decision
- ☐ Right to delete their data

8.4 How are these rights exercised? Describe the workflow.

9. Monitoring plan

9.1 Metrics we'll track (accuracy, error rate, subgroup performance, complaint volume, drift):

9.2 Thresholds that trigger escalation:

9.3 Cadence of review:

9.4 Who owns monitoring:

10. Residual risk and approval

10.1 After mitigations, what residual risk remains?

10.2 Why is that residual risk acceptable given the benefits?

10.3 Approval:

Role	Name	Signature	Date
Business Owner			

AI Governance Lead			
Legal			
Privacy			
Security			
Executive Sponsor (Tier 3)			

10.4 Decision:

- ☐ Approved
- ☐ Approved with conditions (list below)
- ☐ Not approved - remediate and re-submit
- ☐ Retire

Conditions:

Next review date:

Appendix A - Evidence attached

- ☐ Vendor documentation
- ☐ Bias/fairness test results
- ☐ Security test results
- ☐ Data Processing Agreement (DPA)
- ☐ Business Associate Agreement (BAA) - if health
- ☐ Standard Contractual Clauses (SCCs) - if EU
- ☐ Test outputs / sample runs
- ☐ User disclosures (screenshots)
- ☐ Monitoring dashboards
- ☐ Training records

Disclaimer

This document is a template for educational and informational purposes only. It is not legal advice. Consult qualified legal counsel before relying on this template for any compliance decision.